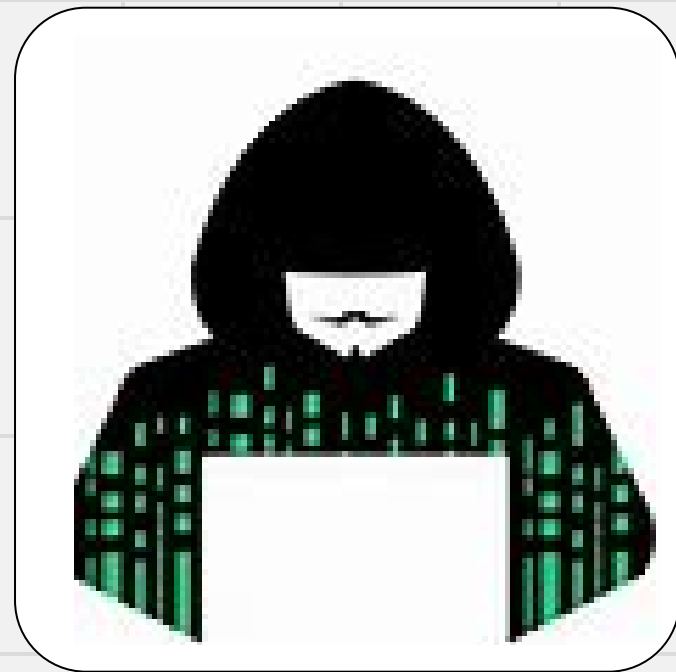


VULNERABILITY RESEARCH

INTRO TO VR

INTRO TO VULNERABILITY RESEARCH



What is Vulnerability Research?

Vulnerability research refers to the process of gathering information to identify and analyze potential problems, whether exploitable or not, in computer systems and software. It involves using various methods and tools to examine source code or other forms of program data in order to discover vulnerabilities that could be exploited by attackers.

[AI GENERATED DEFINITION BASED ON: HACK PROOFING YOUR NETWORK \(SECOND EDITION\), 2002](#)

Why is Vulnerability Research needed?

To ensure the CIA triad is followed within your software applications and computer systems. Breaches can occur for a number of reasons. From user error, cyber criminals to even losing/misplacing unencrypted systems.

Vulnerability Researchers will use a number of tools such as:

- Network Based Scanning
- Host Based Scanning
- Wireless Network Scanning
- Application Scans
- Database Scans

To find the vulnerabilities and generate a report about next steps. These can vary in level of detail depending on the severity of the vulnerabilities found.

DIFFERENCES

There are differences between a vulnerability and an exploit as explained here on the right.



VULNERABILITY

A vulnerability is a weakness or a hole within an application. There are many vulnerabilities with different severity levels. For example:

- Lack of input validation on user input
- Lack of sufficient logging mechanism
- Fail-open error handling
- Not closing the database connection correctly



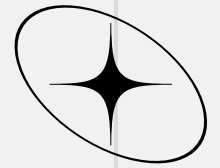
EXPLOIT

An exploit is an action that takes advantage of the vulnerabilities found within applications. Usually in a malicious way. They can:

- Identify flaws
- Bypass security measures
- Gain unauthorised access to systems
- Take control of systems
- Install malware
- Steal sensitive data



COMMON TECHNIQUES



Below are some common techniques used to discover software vulnerabilities

FUZZING

Fuzzing involves providing invalid, random and/or unexpected data inputs into a program to see how it responds. This technique helps discover vulnerabilities by identifying crashes, hangs, memory corruption, or input validation issues.



REVERSE ENGINEERING

This process would decompile or disassemble the binary code of a program in order to understand its structure, functionality and behaviours. You would reconstruct higher level representation of the software from its lower level code.



STATIC ANALYSIS

Also known as SAST - Static Analysis Security Testing. This process allows you to analyse an application's code without having to execute the code itself. It uses automated tools to scan and analyse the source code to identify issues.



DATABASE

WHAT IS CVE?

CVE stands for Common Vulnerabilities and Exposures database and it is used for identifying and naming publicly known cybersecurity vulnerabilities in software and hardware. Each vulnerability in the CVE database is given a unique identifier (CVE ID) in order to make it easier for companies to share intel about security issues across different platforms and tools.

An example of a recent vulnerability published on the NIST website with its CVE ID and CVSS severity

CVE-2024-45462 - The logout operation in the CloudStack web interface does not expire the user session completely which is valid until expiry by time or restart of the backend service. An attacker that has access to a user's browser can use an unexpired session to... [read CVE-2024-45462](#)

Published: October 16, 2024; 4:15:05 am -0400

V3.1: **7.1 HIGH**

WHAT IS NVD?

DATABASE

NVD stands for National Vulnerability Database and it is the U.S. government repository of standards based vulnerability management data represented using the Security Content Automation Protocol (SCAP). This data enables automation of vulnerability management, security measurement, and compliance. The NVD includes databases of security checklist references, security-related software flaws, product names, and impact metrics. It provides more detailed and enriched vulnerability data.

NIST DATABASE

WHAT THE NVD CONTAINS :

The NVD contains more detailed data on the vulnerabilities. Such as:

- **Severity Ratings:** The NVD uses the Common Vulnerability Scoring System (CVSS) to rate the severity of vulnerabilities, helping companies and organisations prioritise which vulnerabilities to address first based on their potential impact.
- **Enhanced Vulnerability Details:** In addition to the CVE entries, the NVD provides further technical details, impact metrics, remediation advice, and information about potential exploitability. This helps security teams understand the broader context of the vulnerability.
- **Search and Filtering Tools:** The NVD allows security professionals to search and filter vulnerabilities by criteria such as software version, product, vendor, and severity score, making it easier to identify vulnerabilities relevant to their systems.

KEY USES FOR SECURITY PROFESSIONALS:

Vulnerability Assessment: By regularly checking the NVD, security teams can stay informed about new vulnerabilities and potential threats to their systems.

Patch Management: The NVD helps professionals identify which patches or updates to prioritise based on the severity and impact of discovered vulnerabilities.

Compliance and Reporting: Many regulatory standards require organisations to manage vulnerabilities actively. The NVD provides standardised data that can be used in audits and reports.

By using the CVE database for tracking and the NVD for deeper analysis and prioritisation, security professionals can better protect their systems from known vulnerabilities.



ETHICAL IMPLICATIONS

Following on from the research paper a number of ethical implactions could arise when detecting a vulnerability such as:

DUTY OF CARE - CLIENT OR THE PUBLIC?

The call would need to be made whether the duty of care to the client outweighs the duty of care to the public if the vulnerability is disclosed. There is a risk in making vulnerabilities public, as this could open it up to exploitation which is a critical concern.

Public disclosure however, could also compel the operator to fix the issues quickly however, it could also open it up to malicious attacks. If the vulnerability is released without the vendors prior knowledge to the issue, 0-day attacks could occur.

COMPANY REPUTATION

When releasing vulnerabilities to the public, another thing to consider would be how it affects a company's reputation. Security researchers must weigh the effects of public transparency against the damage of the operator's credibility and trust which could have a long-term impact with its customers and stakeholders.

RESEARCHERS RESPONSIBILITY

Security researchers have an ethical responsibility to ensure their findings are used for good. The questions of who should be informed first (the operators, government body) or if public disclosure is more justified. The responsibility is in balancing the severity and assessing immediate threats vs long-term security.

BALANCING TRANSPARENCY AND SECURITY

Ethically, the balance between promoting transparency in reporting security flaws whilst maintaining the confidentiality is necessary to protect society from attacks. Researchers would have the dilemma of whether full transparency (disclosure to the public) serves the interests of society better than keeping it contained (to specific stakeholders) that allows time for remediation.

HARM TO SOCIETY

If the vulnerability is disclosed prematurely it would lead to widespread harm, especially since critical infrastructure is essential for society. Researchers need to consider if their actions will cause harm to the public.

ETHICAL IMPLICATIONS - CASE STUDIES

GOOGLE PROJECT ZERO VS MICROSOFT (2017)

Google publishes remote code vulnerability in Microsoft browsers

The flaw could affect all users running vulnerable software — which includes anyone using the bundled browser in Windows 7, Windows 8.1, and Windows 10.

- Duty to Warn vs. Risk of Exploitation: Google felt it was their ethical duty to warn the public, but this also risked attackers exploiting the flaw before a fix was available.
- Reputational Harm: Microsoft argued that the early disclosure harmed their reputation and caused unnecessary panic.
- Potential Harm to Users: The disclosure could have led to real-world attacks, compromising the security of millions of users before Microsoft could patch the vulnerability.

INTEL AND THE SPECTRE/ MELTDOWN VULNERABILITIES (2018)

Meltdown and Spectre: 'worst ever' CPU bugs affect virtually all computers

Everything from smartphones and PCs to cloud computing affected by major security flaw found in Intel and other processors - and fix could slow devices

- Premature Public Disclosure: The early leak of information forced companies to rush incomplete fixes, which in some cases caused system slowdowns and instability.
- Reputational Damage: Intel, in particular, faced significant reputational damage because of the vulnerabilities, as the flaws were intrinsic to the design of their processors.
- Risk to Global Systems: The vulnerabilities affected a broad range of systems, from personal computers to cloud infrastructure, creating the potential for massive harm if they were exploited before fixes could be properly implemented.